

Analisis Hasil OWASP ZAP — Full Scan

DAST AUTOMATED SCAN

Target: OWASP/bWAPP (Buggy Web Application) — Lab IT Audit

1. Informasi Pengujian

Tanggal Pengujian	24 Mei 2026, 22:52
Tool	OWASP ZAP v2.17.0 (by Checkmarx)
Target	http://localhost:8080
Jenis Scan	Full Scan (Spider + Active Scan)
Scan Policy	Default Policy
Total Endpoint	64 endpoint terdeteksi

2. Ringkasan Temuan (Summary of Alerts)

Risk Level	Jumlah Alert
High	0
Medium	5
Low	6
Informational	9

3. Temuan Medium (5)

Temuan	Instances	CWE	OWASP 2021
Absence of Anti-CSRF Tokens	5	352	A01 Broken Access Control
Application Error Disclosure	6	550	A05 Security Misconfiguration
Content Security Policy (CSP) Header Not Set	Systemic	693	A05 Security Misconfiguration
Directory Browsing	Systemic	548	A05 Security Misconfiguration
Missing Anti-clickjacking Header	Systemic	1021	A05 Security Misconfiguration

4. Temuan Low (6)

Temuan	Evidence / Catatan
--------	--------------------

Cookie No HttpOnly Flag	Set-Cookie: PHPSESSID (rentan dicuri via XSS)
Cookie without SameSite Attribute	PHPSESSID (mendukung serangan CSRF)
In Page Banner Information Leak	Apache/2.4.7 di sitemap.xml
Server Leaks Information via "X-Powered-By"	X-Powered-By: PHP/5.5.9-1ubuntu4.14 (versi EOL)
Server Leaks Version via "Server" header	Apache/2.4.7 (Ubuntu)
X-Content-Type-Options Header Missing	Tidak ada 'nosniff' (rentan MIME-sniffing)

5. Temuan Informational (9)

Authentication Request Identified · GET for POST · Session Management Response Identified · Tech Detected (Apache HTTP Server, PHP, Ubuntu, bun) · User Agent Fuzzer · **User Controllable HTML Element Attribute (Potential XSS)** — ZAP menandai input pengguna yang masuk ke atribut HTML, indikasi awal potensi XSS yang perlu verifikasi manual.

6. Insight Kunci: Keterbatasan Automated Scanner

ZAP melaporkan 0 temuan High — padahal pengujian manual + SQLMap membuktikan adanya **SQL Injection (Critical)** dan **Stored XSS (High)** pada aplikasi yang sama.

Penyebab: ZAP hanya meng-crawl halaman permukaan (`login.php` , `portal.php` , `admin/` , `documents/` , `passwords/`) namun **tidak masuk ke modul vulnerability** (`sqli_1.php` , `xss_get.php` , `xss_stored_1.php`) karena:

1. Scan tidak mempertahankan sesi login terautentikasi + `security_level=0` di dalam aplikasi.
2. Spider tidak menemukan URL modul bWAPP secara otomatis (perlu navigasi/seeding manual terlebih dahulu).

Pelajaran audit: Automated DAST scanner memiliki *blind spot*. Tanpa konfigurasi autentikasi yang benar, scanner dapat melewati kerentanan paling kritis. Audit yang baik **selalu mengombinasikan** automated scanning dengan manual testing dan tools terarah (mis. SQLMap).

7. Cross-Validation dengan Nikto

ZAP mengkonfirmasi ulang beberapa temuan Nikto secara independen, memperkuat validitas laporan:

Temuan	Nikto	ZAP
Directory Browsing / Indexing	Terdeteksi	Terdeteksi (Medium)
X-Powered-By / Server version leak	Terdeteksi	Terdeteksi (Low)
Missing X-Frame-Options (clickjacking)	Terdeteksi	Terdeteksi (Medium)
Cookie tanpa HttpOnly	Terdeteksi	Terdeteksi (Low)

Temuan **baru** dari ZAP (tidak ada di Nikto): Absence of Anti-CSRF Tokens, CSP Header Not Set, Cookie without SameSite, X-Content-Type-Options missing.

8. Rekomendasi Remediasi (Konsolidasi)

1. Tambahkan token **Anti-CSRF** unik pada setiap form yang mengubah state.
2. Set security headers: **Content-Security-Policy**, **X-Frame-Options**, **X-Content-Type-Options: nosniff**.
3. Set flag **HttpOnly**, **Secure**, dan **SameSite** pada cookie session.
4. Matikan **directory browsing** (`Options -Indexes`) dan custom error page (sembunyikan error detail).
5. Sembunyikan banner versi server (`ServerTokens Prod` , `ServerSignature Off` , `expose_php = Off`).
6. Update komponen usang: PHP 5.5.9 dan Apache 2.4.7 sudah End-of-Life.

Dokumen ini dihasilkan untuk keperluan mata kuliah IT Audit. Pengujian dilakukan pada lingkungan lab terisolasi (localhost). Detail lengkap setiap instance tersedia pada report mentah ZAP (2026-05-24-ZAP-Report-.pdf).